Disaster Recovery and Business Continuity Planning

Every organization depends on IT systems: email, databases, file servers, banking applications, websites. When these systems stop, money is lost every minute and customers lose trust. **Disaster Recovery (DR)** and **Business Continuity Planning (BCP)** are the two disciplines that make sure an organization can survive and recover when something goes badly wrong.

Introduction to Disaster Recovery

What is Disaster Recovery?

Disaster Recovery is the set of policies, procedures, tools and technologies used to **restore IT systems, applications and data** after a disruptive event. DR is mainly a **technical** discipline. It answers the question: "The servers are gone. How do we get them (and the data) back, and how fast?"

> **Example:** A fire destroys the main server room of a company. DR is the plan that says: restore last night's backup / switch to the replica at the second site, bring up the domain controllers first, then the database, then the applications, in a defined order and within a defined time.

Types of disasters

Category	Examples	Typical impact
Natural	Flood, earthquake, cyclone, fire, lightning	Physical destruction of the building, servers or network links
Hardware / technical	Disk or controller failure, power failure, cooling failure, network outage	Services stop; data may be corrupted
Human	Accidental deletion, wrong configuration, insider sabotage, theft	Data loss or service outage (the most common cause)
Cyber	Ransomware, malware, DDoS, data breach, wiper attacks	Data encrypted or destroyed; systems must be rebuilt
Software	Faulty update, bug, database corruption	Application downtime, bad data

Key DR terms you must know

Term	Meaning	Simple explanation
RPO (Recovery Point Objective)	The maximum amount of data loss, measured in time, the business can accept	"How far back in time can we go?" If RPO = 1 hour, backups or replication must happen at least every hour.

Term	Meaning	Simple explanation
RTO (Recovery Time Objective)	The maximum time allowed to restore a service after a disaster	"How long can we stay down?" If RTO = 4 hours, the system must be working again within 4 hours.
MTD / MAO (Maximum Tolerable Downtime)	The longest outage after which the business itself is in serious trouble	RTO must always be shorter than MTD.
BIA (Business Impact Analysis)	Study that finds which business functions are critical and what an outage costs	It is the source of the RTO and RPO values.
Failover	Switching operations from the primary system to the standby (DR) system	Moving to the backup site.
Failback	Returning operations to the original primary site after it is repaired	Moving back home.
DRP (Disaster Recovery Plan)	The documented step-by-step plan for recovery	The "instruction manual" used during a disaster.

> **Example:** A bank's core banking system has RPO = 0 and RTO = 15 minutes (no data loss, almost no downtime). The staff canteen's ordering app may have RPO = 24 hours and RTO = 3 days. The smaller the RPO and RTO, the **more expensive** the solution.

> **Remember:** RPO is about **data** (how much we can lose). RTO is about **time** (how long we can be down). They are decided by the business, not by the IT team alone.

Introduction to Business Continuity Planning

What is BCP?

Business Continuity Planning is the broader process of making sure that **critical business functions continue to operate** during and after a disruption. It covers people, buildings, suppliers, communication, manual procedures and IT. The international standard is **ISO 22301** (Business Continuity Management Systems).

DR is only **one part** of BCP. BCP asks: "Can the business keep serving customers even while IT is down?" For example, a bank branch may continue with manual paper vouchers while the core system is recovering.

BCP vs DR

Point	Business Continuity Plan (BCP)	Disaster Recovery Plan (DRP)
Scope	Whole organization: people, process, premises, suppliers, IT	IT systems, applications and data only
Goal	Keep critical business operations running	Restore IT services after an outage
Focus	Continuity during the disaster	Recovery after the disaster
Owner	Senior management / business continuity manager	IT department / DR team
Example	Staff work from home; manual billing; alternate office	Restore servers at the DR site; restore database from replica

BCP lifecycle (steps to build a plan)

1. **Policy and scope:** management approval, define what is covered.
2. **Risk assessment:** identify threats (fire, flood, ransomware, power loss) and how likely they are.
3. **Business Impact Analysis (BIA):** find the critical processes, the financial and reputational cost of downtime, and set RTO / RPO.
4. **Strategy selection:** choose how each critical process will be protected (backup, replication, hot site, alternate office, manual workaround).
5. **Plan development:** write the BCP and DRP: roles, contact lists, escalation, recovery steps.
6. **Awareness and training:** every staff member must know what to do and who to call.
7. **Testing and exercises:** walkthroughs, simulations, full DR tests.
8. **Maintenance and review:** update the plan whenever systems, people or the business change (at least once a year).

Main components of a BCP

- **Crisis management team:** people with defined authority who declare the disaster and take decisions.
- **Communication plan:** who informs staff, customers, media and regulators, and through which channels (SMS, call tree, email outside the main system).
- **Alternate work arrangements:** work-from-home, secondary office, shared workspace.
- **Critical resources list:** applications, data, equipment, vendors, licenses and keys needed to restart.
- **Manual workarounds:** paper forms, offline procedures for critical tasks.
- **Vendor and supply chain plan:** contracts and alternatives if a supplier or ISP fails.

> **Remember:** A plan that exists only in a document nobody has read or tested is **not** a plan. Testing and training are what make a BCP real.

Disaster Recovery Site Planning

A **DR site** is a separate location (data center, rented rack space or cloud region) where IT services can be run if the primary site is lost. Planning it properly decides whether the recovery will succeed.

Factors to consider when choosing a DR site

- **Distance and geographic separation:** far enough that one event (flood, earthquake, power grid failure) cannot hit both sites, but close enough for acceptable replication latency. Banks often use a near site (for synchronous replication) and a far site.
- **Power and cooling:** redundant power feeds, UPS, generators and enough fuel.
- **Network connectivity:** dedicated links or VPN between sites with enough bandwidth for replication, plus access for users and customers when failover happens.
- **Risk profile of the location:** not in the same flood zone, fault line or industrial hazard area.
- **Physical and logical security:** access control, CCTV, fire suppression, same security standards as the primary site.
- **Capacity and compatibility:** compute, storage and licenses sized for the critical workloads; compatible hardware or virtualization platform.
- **Cost:** build and run cost versus the cost of downtime.
- **Legal and compliance:** data residency laws and regulator requirements (important for banks and government).
- **Staff access:** can the team physically or remotely reach the site during a disaster?

Application tiering

Not every system needs the same level of protection. Applications are grouped into **tiers**, and each tier gets a different DR approach.

Tier	Description	Example systems	Typical RTO / RPO
Tier 0 / 1	Mission critical; business stops without it	Core banking, domain controllers, payment gateway	Minutes / near zero
Tier 2	Important, but short outage is tolerable	Email, ERP, file servers	Hours / up to 1 hour
Tier 3	Useful, not urgent	Intranet, test systems, reporting	1-3 days / 24 hours
Tier 4	Non-essential	Archives, training systems	Days or weeks / best effort

Data protection and replication basics

- **Backup:** a copy of data stored separately; used to restore to a past point in time. Follow the **3-2-1 rule**: 3 copies of data, on 2 different media, with 1 copy off-site (ideally immutable or offline to resist ransomware).
- **Replication:** continuous copying of data (or entire VMs) to another site so a recent copy is always ready.
  - **Synchronous replication:** a write is confirmed only after both sites have it. RPO ≈ 0, but needs low latency and short distances.
  - **Asynchronous replication:** the primary confirms first, the copy follows a few seconds or minutes later. Works over long distances, but a small data loss is possible.

Types of Disaster Recovery Sites

Site type	Description	RTO	Cost	Typical use
Hot site	Fully equipped duplicate of the primary site, hardware running and data continuously replicated. Can take over almost immediately.	Minutes to a few hours	Very high	Banks, stock exchanges, e-commerce, hospitals
Warm site	Hardware and connectivity are in place, but systems are not fully up to date; data is restored from recent backups or periodic replication.	Several hours to a day or two	Medium	Medium-sized businesses, ERP, email
Cold site	Empty space with power, cooling and network only. Hardware must be brought in, installed and data restored from backups.	Days to weeks	Low	Non-critical systems, small organizations
Mirror site	Exact real-time copy that runs in parallel (active-active). No failover delay at all.	Zero / seconds	Highest	Extremely critical services
Cloud DR (DRaaS)	Replicas or backups kept in a cloud provider; servers are started only during a disaster (pay-as-you-go).	Minutes to hours	Low to medium	Companies avoiding a second data center
Reciprocal / shared site	Two organizations agree to host each other's recovery.	Varies	Low	Rare; trust and capacity issues

> **Example:** Hot site = a second house with the lights on, food in the fridge and your family already there. Warm site = a second house with furniture, but you must bring your food. Cold site = an empty house; you must bring everything.

> **Remember:** Rule of thumb: **the shorter the RTO, the hotter the site and the higher the cost.** Choose the site type according to the BIA, not according to budget alone.

IT Disaster Recovery Switching

DR switching (failover / switchover) is the actual process of moving production services from the primary site to the DR site, and later back again. It must be planned in detail because it is done under pressure.

Failover and failback

- **Planned switchover:** done on purpose (maintenance, DR drill). Primary is still healthy, so data is fully synchronized first and no data is lost.
- **Unplanned failover:** done after a real disaster. Some recent data may be lost (according to RPO).
- **Failback:** after the primary site is repaired, data is replicated back to it and services are returned. It is usually planned for a quiet time.

Typical failover procedure

1. **Detect and assess** the incident (monitoring alerts, site loss report).
2. **Declare the disaster:** only the authorized person (e.g., crisis manager / CIO) may trigger the DR plan.
3. **Activate the DR team** and inform stakeholders using the call tree.
4. **Stop or fence the primary** (if reachable) to avoid "split-brain" where both sites think they are active.
5. **Bring up systems in the planned order:** network and DNS, domain controllers (Active Directory), database servers, application servers, then web / user access.
6. **Redirect users and traffic** (DNS change, load balancer / GSLB, VPN or routing change).
7. **Validate:** test that critical applications work, data is consistent, users can log in.
8. **Communicate** the status to management, users, customers and regulators.
9. **Operate at the DR site** and monitor, while repairing the primary.
10. **Failback:** reverse replication, sync data, schedule the cut-over and return to primary.
11. **Review:** document lessons learned and update the plan.

Technologies used for switching

Method	How it works
DNS / Global Server Load Balancing (GSLB)	The domain name is pointed to the DR site IP address. Use a low TTL so the change spreads quickly.
Virtual machine replication	Tools such as **Hyper-V Replica**, **VMware SRM / vSphere Replication** or **Azure Site Recovery** keep a copy of each VM at the DR site and start it on failover.

Method	How it works
Database replication / clustering	SQL Server Always On Availability Groups, log shipping, Oracle Data Guard keep a standby database that can be promoted.
Storage replication	SAN-level (array-to-array) replication copies disk blocks to the DR array.
Network switching	BGP / routing changes, stretched VLANs or VPN updates so users reach the DR site.

Active-passive vs active-active

Model	Meaning	Pros	Cons
Active-passive	One site serves users; the other waits on standby.	Simpler, cheaper	Failover delay; standby hardware idle
Active-active	Both sites serve users at the same time and each can take over the other's load.	Almost zero downtime; resources fully used	Complex, expensive, data consistency challenges

> **Hyper-V link:** Since your notes use Hyper-V, remember that **Hyper-V Replica** supports **Test Failover** (safe test without disturbing production), **Planned Failover** (no data loss) and **Unplanned Failover** (real disaster), followed by **Reverse Replication** to prepare the failback.

DR Testing Procedures

An untested DR plan almost always fails when it is needed: backups that cannot be restored, outdated IP addresses, missing passwords or licenses. Regular testing proves that the plan really meets the RTO and RPO.

Test type	What is done	Impact on production
Plan review / checklist	Team reads the plan and checks that contacts, assets and steps are up to date.	None
Walkthrough / tabletop exercise	Team sits together and discusses a scenario ("The data center is flooded. What do we do?") step by step.	None
Simulation	A realistic scenario is played out; people perform tasks, but no real failover.	Minimal
Parallel test	The DR site is started and tested while production continues to run normally.	Low

Test type	What is done	Impact on production
Full interruption (failover) test	Production is actually switched to the DR site, then switched back.	High; done in a planned window
Backup restore test	Randomly selected backups are restored to prove that data is usable.	None

Steps for a DR test

1. Define objectives and scope (which systems, which scenario).
2. Get management approval and choose a safe time window.
3. Notify all participants and users.
4. Take fresh backups and prepare a rollback plan.
5. Run the test following the written steps; record start and finish times.
6. Verify applications, data integrity and user access.
7. Measure the **actual RTO and RPO** and compare with targets.
8. Write an after-action report with problems found, then fix them and update the DRP.

> **Remember:** Test at least **once a year**, and also after any major change (new application, new data center, migration). Critical systems such as banking are tested more often.

Key Concerns and Challenges

- **Cost:** a hot site doubles hardware, licensing, power and staff cost. Management needs a clear BIA to justify it.
- **Data consistency and latency:** keeping two sites in sync over a WAN is difficult; synchronous replication limits distance.
- **Complexity:** applications depend on each other (AD, DNS, database, application). Wrong start order causes failures.
- **Plan becomes outdated:** servers, IPs, vendors and staff change; if the plan is not updated, it fails.
- **Human factors:** unclear roles, panic under stress, key person unavailable. Cross-training and clear authority help.
- **Ransomware:** replication copies the infected or encrypted data to the DR site too. Immutable, offline or air-gapped backups and point-in-time recovery are needed.
- **Testing disruption:** full tests are risky and need business agreement.
- **Compliance and regulation:** sectors like banking, health and government must meet strict recovery standards and reporting.
- **Dependencies on third parties:** ISP, cloud provider, SaaS vendors, power utility may also fail.
- **Skills and documentation:** the plan must be understandable by someone who did not design the system.

Banking Site Disaster Recovery Technologies

Banks cannot accept long outages or lost transactions. Money transfers, ATM and card systems, internet banking and the core banking system (CBS) run 24/7. Therefore banks use the most advanced DR design: usually **three sites** and real-time replication.

Typical banking DR architecture

- **Primary Data Center (DC):** runs production.
- **Near DR site (same city / short distance):** connected by a high-speed link with **synchronous replication**, giving **RPO = 0** (zero data loss).
- **Far DR site (different region):** uses **asynchronous replication** to protect against a regional disaster. Small data loss possible but extremely protected.
- Many banks run **active-active** for some services (ATM switch, internet banking) and **active-passive** for the core banking database.

Technologies commonly used

Technology	Purpose
SAN / storage array replication (e.g., EMC SRDF, NetApp SnapMirror, IBM Metro/Global Mirror, Hitachi TrueCopy)	Block-level synchronous / asynchronous replication of core banking data between sites
Database replication (Oracle Data Guard, SQL Server Always On, IBM Db2 HADR)	Keeps standby databases up to date; allows fast promotion
Server clustering and virtualization (failover clusters, VMware HA / SRM, Hyper-V clusters)	Automatic restart of workloads on other nodes or sites
Global load balancers and redundant links (multiple ISPs, MPLS, SD-WAN)	Direct customers and branches to the active site; remove single points of failure
Backup systems (disk, tape, VTL, immutable / WORM backups, air-gapped copies)	Long-term retention, protection against ransomware and corruption
Redundant power and cooling (dual feeds, UPS, generators)	Keeps the data center running
Monitoring and orchestration tools	Automate failover steps and alert the team

Banking-specific requirements

- Very low RTO (minutes) and RPO (zero for core transactions).
- Compliance with central bank guidelines and international standards (ISO 22301, ISO 27001, PCI DSS for cards).
- Regular, documented DR drills and reports to the regulator.
- Strong security and encryption for replicated data in transit and at rest.

- A **DR switching drill** at defined intervals where real production is run from the DR site for a period.

Case Studies

Case 1: Maersk and the NotPetya attack (2017)

The shipping giant **A.P. Moller-Maersk** was hit by the **NotPetya** malware, which spread across its network through Windows systems and destroyed data on thousands of computers. Terminals and ports stopped, and the company reported losses of about **USD 300 million**. Most of its domain controllers were wiped. The company was able to recover because **one domain controller in its Ghana office** happened to be offline (due to a power cut) during the attack and held a clean copy of Active Directory. Maersk rebuilt thousands of servers and tens of thousands of PCs in around ten days.

> **Remember:** Lessons: keep **offline / isolated backups** (especially of Active Directory), segment the network, patch systems, and test full-rebuild procedures.

Case 2: OVHcloud data center fire (2021)

In March 2021 a fire destroyed one data center (SBG2) of the European cloud provider **OVHcloud** in Strasbourg and damaged another. Millions of websites went offline and some customers permanently lost data, because their backups were stored in the **same building** as the primary data.

> **Remember:** Lessons: **backups must be off-site** and in a different fault domain; the cloud is not automatically a backup; customers must read the provider's responsibility model.

Case 3: GitLab database incident (2017)

A GitLab engineer accidentally deleted the production database directory on the wrong server while fixing a replication problem. When they tried to restore, they discovered that **several backup mechanisms were not working**, and about six hours of data were lost.

> **Remember:** Lessons: **a backup that has not been tested is not a backup**; automate checks and monitor backup jobs; apply safeguards against human error.

Endpoint Security

What is Endpoint Protection

An **endpoint** is any device that connects to the organization's network: laptops, desktops, servers, smartphones, tablets, POS machines, printers and IoT devices. Every endpoint is a possible **entry door** for attackers, and users (who can click bad links) operate them, so endpoints are the most commonly attacked part of a network.

Endpoint protection (also called an **Endpoint Protection Platform, EPP**) is the combination of software and policies that **prevents, detects and responds to threats on endpoints**. It is installed as an **agent** on each device and managed centrally from a console.

> **Example:** Your office firewall is the main gate of the building. Endpoint security is the lock, alarm and guard inside every single room, so if someone enters through a laptop brought from home or a USB stick, the room is still protected.

Endpoint Threats and Vulnerabilities

Common threats

Threat	Description
Malware (virus, worm, trojan, spyware)	Malicious software that damages, steals or spies
Ransomware	Encrypts files and demands payment for the key
Phishing and social engineering	Fake emails or sites that trick users into giving passwords or running malware
Fileless attacks	Use legitimate tools (PowerShell, WMI) in memory, leaving no file for a traditional antivirus to scan
Zero-day exploits	Attacks that use vulnerabilities for which no patch exists yet
Removable media threats	Infected USB drives
Credential theft	Keyloggers, stealing saved passwords or password hashes from memory
Insider threats	Employees who leak or destroy data, intentionally or accidentally
Lost or stolen devices	Unencrypted laptops and phones expose data

Common vulnerabilities

- Unpatched operating systems and applications.
- Weak or reused passwords, no multi-factor authentication.

- Users with local administrator rights.
- Unnecessary services, open ports and legacy protocols (such as SMBv1).
- Missing disk encryption; unmanaged personal (BYOD) devices.
- Shadow IT: software installed without IT approval.

Traditional Antivirus Vs. Modern Endpoint Protection

Point	Traditional antivirus (AV)	Modern endpoint protection (NGAV / EPP / EDR)
Detection method	Mostly **signature-based**: compares files with a database of known malware	Behavior analysis, machine learning, heuristics, reputation and threat intelligence plus signatures
Unknown (zero-day) threats	Weak; cannot detect what it has not seen	Can detect suspicious behavior even for new malware
Fileless attacks	Often missed	Detected through memory and process monitoring
Visibility	Only a "clean / infected" result	Full telemetry: processes, network connections, registry changes, user actions
Response	Delete or quarantine the file	Isolate the device, kill processes, roll back changes, investigate, hunt threats
Management	Often standalone per PC	Centralized cloud or on-premise console, policies for thousands of devices
Updates	Periodic signature updates	Continuous cloud intelligence
Scope	Only malware	Malware, exploits, ransomware, device control, web control, encryption, patching

Features and Capabilities

A modern endpoint security product combines many layers (defence in depth) in a single agent:

- **Next-Generation Antivirus (NGAV):** signature + behavior + machine learning scanning of files and memory in real time.
- **Anti-ransomware / behavior detection:** detects mass file encryption and can roll back changes.
- **Exploit prevention:** blocks techniques used to exploit vulnerabilities in applications.
- **Host firewall and HIPS (Host Intrusion Prevention):** controls network traffic and application activity on the device.
- **Web control and web filtering:** blocks malicious and unwanted websites.

- **Application control (allow-listing):** only approved programs may run.
- **Device control:** manage USB drives and other removable devices (block, read-only, allow list).
- **Email and phishing protection:** scans attachments and links.
- **Vulnerability and patch management:** finds missing patches and installs them.
- **Disk and file encryption:** protects data if a device is lost (e.g., BitLocker management).
- **Data Loss Prevention (DLP):** stops sensitive data from leaving through USB, email or cloud.
- **Sandboxing:** runs suspicious files in an isolated environment before allowing them.
- **EDR capabilities:** continuous recording, investigation and response (explained below).
- **Centralized reporting and compliance:** dashboards, alerts, audit reports.

Endpoint Protection Best Practices

1. **Patch quickly:** keep OS, browsers, Office, Java and third-party software updated (use WSUS / SCCM / patch tools).
2. **Least privilege:** normal users should not be local administrators.
3. **Enable MFA** for remote access, email and admin accounts.
4. **Use encryption** (BitLocker) on laptops and removable drives.
5. **Control USB and removable media** and block autorun.
6. **Application allow-listing** (AppLocker / WDAC) on servers and sensitive machines.
7. **Harden configurations:** disable unused services, SMBv1, old protocols; apply security baselines through Group Policy.
8. **Keep the endpoint agent updated and tamper-protected**, with a password to uninstall it.
9. **Back up regularly** (3-2-1 rule) and test restores, which is the best ransomware defence.
10. **Monitor and log centrally**; send logs to a SIEM if available.
11. **User awareness training:** phishing simulations and safe-use education.
12. **Network segmentation and firewalls** to limit spreading.
13. **Have an incident response plan:** know how to isolate a device and who to call.

Endpoint Detection and Response

EDR (Endpoint Detection and Response) goes beyond prevention. It assumes that **some attacks will get through** and gives security teams the visibility and tools to detect and stop them quickly.

How EDR works

1. **Collect:** the agent records telemetry such as process starts, file changes, registry edits, logins, network connections and command lines.
2. **Analyze:** data is sent to a central server or cloud, where rules, behavior analytics, machine learning and threat intelligence look for suspicious patterns (for example, Word starting PowerShell which then contacts an unknown server).

3. **Alert and prioritize:** the console raises alerts and shows the **attack story / timeline**.
4. **Investigate:** analysts see exactly what happened, which files and accounts were involved, and how far it spread.
5. **Respond:** actions such as **isolate the host from the network**, kill a process, quarantine or delete files, block a hash, roll back changes, or collect forensic data.
6. **Hunt:** security teams search historical data for hidden threats (threat hunting).

Key capabilities

- Continuous monitoring and recording (the "flight recorder" of the endpoint).
- Behavioral detection using the **MITRE ATT&CK** framework.
- Forensics and root cause analysis.
- Automated and manual response / remediation.
- Integration with SIEM, SOAR and threat intelligence.

EDR vs. XDR vs. MDR Key Differences

Point	EDR	XDR	MDR
Full name	Endpoint Detection and Response	Extended Detection and Response	Managed Detection and Response
What it is	A **technology** focused on endpoints	A **platform** that unifies several security layers	A **service** (people + technology) provided by an outside company
Data sources	Endpoints (laptops, servers)	Endpoints + network + email + cloud + identity + servers	Uses EDR/XDR tools of the client or provider
Who operates it	Your own security team	Your own security team (with automation)	The provider's 24x7 security analysts (SOC)
Strength	Deep endpoint visibility and response	Correlates events across layers; fewer blind spots; less alert noise	Expertise and round-the-clock monitoring without hiring a full SOC
Best for	Organizations with security staff	Larger organizations wanting unified visibility	Small / medium organizations lacking security staff

> **Remember:** Easy way: **EDR** = endpoints only. **XDR** = EDR extended to everything. **MDR** = someone else watches and responds for you.

Architecture of Endpoint Security Solutions

Most enterprise solutions use a **client-server (agent-console)** architecture:

- **Management server:** the central brain that stores policies, tasks, events and reports (for example, Kaspersky Security Center, Microsoft Defender for Endpoint cloud, CrowdStrike cloud).
- **Database:** stores configuration, inventory and event data (SQL Server or similar).
- **Management console:** the interface (MMC or web) used by administrators to create policies, view alerts and deploy software.
- **Endpoint agents:** the security software on each device that enforces policies, scans, reports to the server and can act locally without the network.
- **Communication / administration agent:** talks to the management server, receives policies and sends status.
- **Update / distribution points:** relay servers that download updates once and distribute them to clients to save bandwidth (useful for branch offices).
- **Cloud threat intelligence:** reputation and analysis services that help detect new threats very quickly.
- **Integrations:** Active Directory (for grouping computers and users), SIEM, email gateway, firewall, ticketing.

Typical policy structure

Devices are placed into **administration groups** (for example by department or OU). **Policies** (what the agent must enforce) are applied to groups and inherited down the hierarchy. **Tasks** (what to do now or on schedule: scan, update, install) are also created for groups. Exceptions are handled per group or per device.

Example Endpoint Security Deployment using Kaspersky

Kaspersky's enterprise solution has two main parts: **Kaspersky Security Center (KSC)**, the central management platform, and **Kaspersky Endpoint Security (KES)** for Windows/Linux/macOS, plus **Kaspersky Security for Windows Server** for servers. The Network Agent connects each device to KSC.

Components

Component	Role
Administration Server	The core service that stores policies, tasks, events, inventory and the update repository; uses a database (SQL Server or others)
Administration Console / Web Console	Where administrators work (MMC-based console or browser-based web console)
Network Agent	Installed on each client; links the device to the Administration Server and applies policies and tasks
Kaspersky Endpoint Security (KES)	The actual protection application on endpoints

Component	Role
Installation packages	Prepared installers of KES / Network Agent that are pushed to computers
Administration groups	Logical groups of managed devices that receive the same policies

Pre-deployment planning

- Check the system requirements for the server (OS, RAM, disk) and the database.
- Remove or disable other antivirus products (conflicts).
- Prepare a service account and make sure DNS and AD are healthy; open the needed firewall ports (by default the Network Agent connects to the Administration Server on TCP 13000, and the console connects on TCP 13291; check the vendor documentation for your version).
- Decide the group structure (e.g., Servers, Workstations, Branches) and the policy design.
- Prepare a Windows Server 2022 machine (usually a VM) for KSC and enough storage for updates.

Deployment steps

1. **Install Kaspersky Security Center (Administration Server)** on the management server. Choose the database (SQL Server / Express), service account, language and the Administration Server name. Open the console afterwards.
2. **Run the Quick Start Wizard.** It creates initial policies and tasks, asks for the license key or activation code, and configures updates and the notification options.
3. **Configure the update source:** Administration Server downloads antivirus databases and software updates from Kaspersky and distributes them to clients. Create a "Download updates to the repository" task.
4. **Create the administration group structure** and move or discover devices (by AD domain polling, IP range or network list).
5. **Create installation packages** for Kaspersky Endpoint Security (and the Network Agent) from the Remote Installation section; add the license key.
6. **Deploy remotely:** use **Remote Installation Wizard / "Install application" task**. Select the package, the target computers or groups, enable "Install required components" and provide an account with local admin rights. Alternatively use a Group Policy or standalone installer.
7. **Verify:** computers appear as "Managed", in "OK" status, with databases up to date.
8. **Create and tune policies:** real-time protection, behavior detection, anti-ransomware, firewall, web control, device control, application control, encryption, exclusions, and password protection for uninstall.
9. **Schedule tasks:** regular full scans, update tasks, patch/vulnerability scan tasks.

10. **Set up reports and notifications** for infected devices, outdated databases and offline clients.
11. **Deploy on servers** with the proper server edition and server-specific policies (exclusions for AD, SQL, Hyper-V).

After deployment: day-to-day management

- Monitor the dashboard for **devices not protected, outdated databases and active threats**.
- Investigate events and take actions (scan, isolate, remove).
- Keep KSC itself updated and **back it up** (database and settings).
- Review policies periodically and maintain exclusions only where necessary.

> **Note:** Screens and menu names differ slightly between Kaspersky versions (for example, the Web Console in newer releases). Add your own screenshots from your lab next to these steps in your book.